FITNESS PRO — BACKEND SECURITY SPECIFICATION

# REGISTER ENDPOINT SECURITY PLAN

Brute-force, bot, spam, SQL Injection, XSS, enumeration, oversized request ve sahte veri saldırılarına karşı bütüncül backend koruma şartnamesi.

**ÖNEMLİ İLKE:** Frontend güvenlik katmanı değildir! Frontend üzerindeki tüm kontroller backend tarafından istisnasız tekrar uygulanmalıdır. Database son savunma hattıdır.

## 01 & 02 — REGISTER RATE LIMIT & ANAHTAR YÖNETIMI

### Kural & Limit Parametreleri

- **Pencere:** 15 Dakika
- **Maksimum İsteği:** IP başına 10 register isteği
- **Aşım Yanıtı:** `HTTP 429 Too Many Requests` + `Retry-After: 900`
- **İzolasyon:** Login Rate Limit ile Register Rate Limit tamamen ayrı tutulmalıdır.

### Anahtar & IP Spoofing Koruması

- **Varsayılan Anahtar:** Client IP
- **Trusted Proxy:** Proxy/Docker/Reverse Proxy arkasında `X-Forwarded-For` header'ına direkt güvenilmemeli, trusted proxy yapılandırılmalıdır.
- **Depolama:** Dev: `ConcurrentDictionary` / Prod: Distributed Redis.

## 03 — REQUEST VALIDATION & STRING SINIRLARI

| Alan | Min / Max Uzunluk | Format / Kurallar | Güvenlik Engeli |
|---|---|---|---|
| `Name` / `Surname` | 2 / 100 Karakter | Boş kabul edilmez, trimming uygulanır | Control & Null karakter engeli |
| `Username` | 3 / 50 Karakter | `A-Z`, `a-z`, `0-9`, `_` | HTML/Script payload, Null byte engeli |
| `Email` | Max 255 Karakter | Geçerli email formatı, DB UNIQUE | Email enumeration & Spam engeli |
| `Password` | 8 / 128 Karakter | Büyük/küçük harf, rakam, özel karakter | Zayıf parola & DoS (bcrypt/Argon2) engeli |
| `PasswordRepeat` | - | `Password` ile birebir eşleşmeli | Hatalı parola kaydı engeli |

## 04 & 05 — LEVEL VE ROLE ESCALATION KORUMASI

Register sırasında kullanıcı yetki veya seviye belirleyemez.

- **Level Whitelist:** Yalnızca `Acemi`, `Orta`, `Uzman` kabul edilir. `Level = Admin` vb. istekler `HTTP 400 Bad Request` ile reddedilir.
- **Role Escalation:** Request body içerisinde gönderilen `Role`, `IsAdmin`, `IsCoach`, `Permissions` alanları kesinlikle **dikkate alınmaz**. Varsayılan rol backend tarafından zorunlu olarak `User` atanır.

## 06 & 07 — SQL INJECTION & DUPLICATE ACCOUNT KORUMASI

### Parameterized Query

Tüm sorgularda tip korumalı parametreler kullanılır:

```
command.Parameters.Add("@Username", SqlDbType.NVarChar, 100).Value = model.Username;
```

### Database Constraints

Backend validation atlatılsa dahi son savunma hattı:

- `Users.Username` → UNIQUE
- `Users.Email` → UNIQUE

## 08 & 09 — ENUMERATION & ERROR HANDLING

Saldırganların sistemdeki kayıtlı e-posta veya kullanıcı adlarını taramasını önlemek için genel mesajlar tercih edilmelidir:

- **Hatalı Response:** `"Bu e-posta adresi zaten kayıtlı."` (Veri ifşası yapar)
- **Güvenli Response:** `"Bu bilgilerle kayıt gerçekleştirilemedi."` (Public API için önerilen)
- **Exception Maskeleme:** Database `SqlException` detayları dışarı sızdırılmaz, internal loglara yazılır.

## 10, 11 & 12 — XSS, REQUEST SIZE & NULL/WHITESPACE CHECKS

- **Request Body Limit:** Register endpointi için request boyutu `64 KB - 256 KB` ile sınırlandırılır.
- **Input Sanitization:** Null (`null`), boş string (`""`), sadece boşluk (`" "`), tab/newline (, ) girdiler reddedilir.
- **XSS Protection:** Backend girdileri HTML olarak render etmez; Frontend tarafında DOM manipülasyonunda `innerHTML` yerine `textContent` zorunlu kılınır.

## 14, 15 & 16 — PAROLA GÜVENLİĞİ VE DEPOLAMA (PASSWORD STORAGE)

**Mevcut Durum:** SHA-256 + Salt ➔ **Production Hedefi:** Parola hashing için yavaş ve password-specific algoritma olan **Argon2id** (veya PBKDF2 / bcrypt) mimarisine geçiş yapılacaktır.

- Parolalar veritabanında, loglarda, JWT, response veya konsolda kesinlikle **plaintext** olarak tutulmaz/yazdırılmaz.
- **Log Maskeleme:** Exception ve request loglarında `Password`, `PasswordHash`, `Salt`, `JWT Token` alanları otomatik olarak maskelenir.

## 17, 18, 19 & 20 — BOT KORUMASI, EMAIL VERIFICATION & ABUSE MANAGEMENT

### CAPTCHA & Bot Shield

Cloudflare Turnstile veya reCAPTCHA v3. Şüpheli/yoğun trafikte dinamik CAPTCHA tetiklenir.

### Email Verification & Rate Limit

Tek kullanımlık, süreli verification token. E-posta gönderimi rate limit'e tabidir (Örn: 1 mail / 60 sn).

## 21 - 29 — ALTYAPI GÜVENLİĞİ (HTTPS, CORS, HEADERS, STATUS CODES)

| Kategori | Konfigürasyon / Uygulama Şekli |
|---|---|
| **HTTPS** | Tüm register trafiği şifrelenmiş TLS/HTTPS kanalı üzerinden iletilir. Plaintext HTTP reddedilir. |
| **CORS** | Production ortamında `AllowAnyOrigin` yasaktır. Sadece `https://fitnesspro.example` whitelist edilir. |
| **Security Headers** | `X-Content-Type-Options: nosniff`, `Content-Security-Policy`, `HSTS`, `Referrer-Policy`. |
| **HTTP Statuses** | `201 Created` (Başarılı), `400 Bad Request` (Validation), `429 Too Many Requests` (Rate Limit). |

## 30 — REGISTER SECURITY FLOW (UÇTAN UCA AKIŞ)

```
Client → HTTPS → CORS → Request Size Limit → Rate Limit (429) → Validation → Whitelist (Level) → Role Override Protection → Abuse/CAPTCHA → DB Unique Check → Password Hash (Argon2id) → Transaction → Default Role = User → Email Verification → 201 Created
```

## 35 — UYGULAMA YOL HARITASI (IMPLEMENTATION PHASES)

**PHASE 1 (ŞİMDİ):** Register RateLimitService (10 req/15 min/IP), HTTP 429, Retry-After, Controller Entegrasyonu.

**PHASE 2:** Backend Model Validation, String Limits, Level Whitelist, Request Body Size Limit.

**PHASE 3:** Parameterized SQL, DB UNIQUE Constraints, Duplicate Exception Handling, Transaction Kontrolü.

**PHASE 4:** Role Escalation Protection (Role=User zorlaması), Security Logging & Error Maskeleme.

**PHASE 5:** CAPTCHA / Turnstile Entegrasyonu, Email Verification & Verification Rate Limit.

**PHASE 6 (PROD):** Argon2id Hashing, Production CORS, HTTPS, Security Headers, Distributed Redis Rate Limit, Monitoring.

## 36 — TEST SENARYOLARI ÖZETI

| Test ID | Senaryo / İstenen Eylem | Beklenen Sonuç |
|---|---|---|
| `TEST 01-05` | Normal Kayıt / Eksik/Uzun Username / Geçersiz Email / Parola Mismatch | `201 Created` / `400 Bad Request` |
| `TEST 06-07` | Geçersiz Level (Level=Admin) / Role Injection (Role=Admin) | Level reddedilir (400) / Role dikkate alınmaz (User atanır) |
| `TEST 08-11` | Duplicate Username-Email / SQLi Payload / XSS Payload | Kayıt reddedilir, zararlı kodlar etkisizleştirilir |
| `TEST 12-14` | 11. Register İsteği / 429 sonrası tekrar deneme / 15 dk sonra deneme | `HTTP 429` / `HTTP 429` / `201 Created` (Sistem açılır) |
| `TEST 15-17` | Büyük Request / CAPTCHA Başarısız / Email Verification Akışı | Reddedilir / Reddedilir / Pending ➔ Verified ➔ Active |